AI-Driven Social Engineering Attack Simulation & Awareness Platform

Full Technical Architecture, Simulation Engine & Pedagogical Specification

Document Version: 2.4.0 (Production Release)	**Target Environment:** Node.js 22 / React 18 / MongoDB Atlas
Core AI Engine: Groq LLM Cloud (GPT-OSS 120B / 20B)	**Vision Module:** Tesseract OCR + Heuristic Parser
Channels: 8 Attack Vectors (Email, Call, WhatsApp, Insta, etc.)	**Classification:** Enterprise Cyber Defense Training Platform

1. Executive Summary & Core Mission

The **AI-Driven Social Engineering Attack Simulation and Awareness Platform** is an experiential cybersecurity education ecosystem engineered to bridge the critical gap between static theoretical security knowledge and real-time behavioral defense under active psychological pressure. Traditional security awareness programs rely almost exclusively on predictable multiple-choice quizzes or sporadic simulated email templates. However, modern threat actors operate across multichannel workflows—combining voice calls (vishing), instant messaging (WhatsApp, Telegram, Instagram DM), corporate chat (Slack, Teams), SMS (smishing), and counterfeit SSO login portals.

This platform replaces passive training with **hyper-realistic, interactive, generative attack simulations** and **forensic threat triage challenges**. An integrated generative AI engine analyzes threat briefs or uploaded screenshots, predicts attack channels, synthesizes believable adversary personas, and executes real-time multi-turn behavioral engagements while auditing every user keystroke, voice utterance, and inspection decision.

2. Full-Stack System Architecture

The application is engineered as a high-performance, decoupled client-server architecture:

Layer	Technologies	Core Responsibilities
Frontend UI	React 18, Vite 6, Tailwind CSS 3, Lucide React	Pixel-accurate web replicas of Gmail, WhatsApp Web, Instagram DM, Telegram, Phone dialer, and SSO portals.
Audio / Voice	Web Speech API, Web Audio API (AudioContext)	Bidirectional voice loop, continuous speech-to-text with silence debouncing, multilingual TTS, DTMF touch-tones.
Backend Server	Node.js 22 (ESM), Express 4, Multer	REST API microservices, streaming multipart upload handling, scenario validation, telemetry aggregation.
AI & Vision	Groq Cloud SDK (GPT-OSS 120B/20B), Tesseract.js	Dynamic scenario synthesis, attack vector prediction, real-time persona pushback, screenshot OCR parsing.
Database	MongoDB Atlas, Mongoose 9	State persistence for active sessions, immutable telemetry audit logs, risk scores, and awareness reports.
Verification	Vitest, Supertest, React Testing Library, JSDOM	Automated unit, integration, and UI component testing suite across backend and frontend layers.

3. The 8-Vector Attack Simulation Sandbox

All simulations execute inside sandboxed, interactive client replicas dispatched dynamically by **SimulationRenderer.jsx**:

1. Email Simulation (Gmail Web Replica): Replicates Gmail with interactive inbox views, search filter bars, sender avatars, and hoverable link inspectors that show true destinations vs. spoofed display URLs. Includes a native 'Report Phishing' modal for tagging red flags.

2. Voice Call / Vishing Simulation: Smartphone dialer UI featuring authentic Web Audio API DTMF dual-frequency tones. Executes continuous Speech-to-Text with 1.8-second silence debouncing, regional TTS voices (ta-IN, te-IN, hi-IN, en-US), and instant credit card / PIN disclosure detection.

3. WhatsApp Simulation (WhatsApp Web): Replicates WhatsApp Web with real-time chat lists, online activity indicators, official verified badges, and realistic conversational pretexts such as family emergencies and CEO gift card requests.

4. Instagram Simulation (Instagram Direct): Dark-mode Instagram Direct UI with verified badges, profile metadata, and interactive threads simulating copyright infringement lures and verification badge scams.

5. Telegram Simulation (Telegram Web): Telegram Web desktop client replica featuring automated bot reply loops, channel broadcast lures, and weaponized archive download alerts.

6. Mobile SMS Simulation (Smishing): Constrained within a 420px mobile bezel with alphanumeric telecom sender IDs (e.g., VM-HDFCBK), urgent KYC deactivation warnings, and shortened phishing URL links.

7. Workplace Chat Simulation (Slack / Teams): Corporate collaboration client simulating IT Helpdesk impersonation, urgent payroll deposit modification requests, and MFA session push fatigue lures.

8. Counterfeit Website Portal (SSO Clone): Full in-browser clone simulating single sign-on portals (Microsoft 365, Google Workspace, Banking). Features an interactive address bar and active form fields that capture and score credential submission.

4. Dual-Mode Pedagogical Methodology

The platform implements two complementary learning methodologies addressing experiential defense versus analytical triage:

Dimension	Standard Mode (Experiential)	Cyber Detective Mode (Analytical)
Trainee Role	Victim under direct attack	Forensic Security Analyst triaging evidence
Adversary Interaction	Live, multi-turn, conversational pushback	Static evidence inspection with Replay Audio
Microphone / Input	Microphone active; STT listens continuously	Microphone strictly disabled; analysis only
Ground Truth	100% Malicious active attack	Mix of authentic (REAL) and malicious (FAKE)
Golden Rule Policy	Attacker tries to force credential clicks	Authentic REAL communications contain zero links
Win Condition	Safe exit, refusing info, hanging up, reporting	Submitting accurate verdicts (Legitimate vs Attack)
Final Deliverable	Awareness Report with vulnerability score	Detective Triage Report Card & Accuracy %

5. Multilingual AI & Indian Regional Localization

Cybercriminals increasingly exploit regional languages to disarm users who associate phishing exclusively with English. The platform features comprehensive, native Unicode script support for major Indian languages alongside English:

Language	Unicode Block	Voice Locale	Vishing / Call Keywords Handled
Tamil	U+0B80 - U+0BFF	ta-IN	■■■■, ■■■■■■■■, ■■■■■■■■■, ■■■■■, ■■■■■■, ■■■■■■■■■
Telugu	U+0C00 - U+0C7F	te-IN	■■■■, ■■■■■, ■■■■■■■, ■■■■■■■, ■■■■■■■■■■■, ■■■■■■■■■
Hindi	U+0900 - U+097F	hi-IN	■■■, ■■■■, ■■■■■, ■■■■■, ■■■■■■■■, ■■■■ ■■■, ■■■■ ■■■■
Kannada	U+0C80 - U+0CFF	kn-IN	■■■■■, ■■■■■, ■■■■■■■■, ■■■■, ■■■■■■■■■■■
Malayalam	U+0D00 - U+0D7F	ml-IN	■■■■, ■■■■, ■■■■■■■■■, ■■■■■■■■, ■■■■■■
English	ASCII / Latin	en-US	phone call, voice call, vishing, telephone, bank call, caller, robocall

Dual-Language Architecture Constraint: *While all human-facing text (email subjects, message bodies, caller speech, forensic indicators) is rendered in native Unicode script, all JSON structural schema keys (scenarioId, channel, type, callData, callerSpeech) remain strictly in ASCII English. This eliminates runtime parsing corruption across browser engines.*

6. Telemetry Pipeline & Event Taxonomy

Every trainee interaction is audited via a non-blocking asynchronous telemetry pipeline. The frontend **telemetryService** dispatches events to /api/events with millisecond timestamps and metadata payloads:

- scenario_viewed: Dispatched on initial mount. Records the initial view, attack category, and difficulty.
- message_opened: Fired when user clicks an email thread, SMS card, or chat contact to expand contents.
- virtual_link_clicked: Triggered when user clicks a simulated phishing link, recording target URL and inspection history.
- credential_submitted: Fired when a user enters passwords, OTPs, or card credentials in a form or dialpad.
- speech_input_provided: Dispatched during voice call turns with full transcribed speech for leak analysis.
- dtmf_keypad_pressed: Captures numeric dialpad inputs (used to track PIN/card disclosure via touch tones).
- threat_reported: Emitted when user uses native 'Report Phishing/Threat' button with identified forensic flags.
- safe_exit: Positive exit signal when trainee hangs up, leaves suspicious domain, or refuses credential sharing.

7. Behavioral Scoring Algorithm & Remediation

When a session concludes, **scoringService.js** evaluates telemetry to produce an objective risk profile:

• **Base Vigilance Calculation:** Vigilance Score = (Reporting Points + Indicator Recognition) - Penalties.
• **Reporting Efficiency (+50 pts):** Awarded for correctly reporting the attack, scaled inversely by the delay between viewing and reporting.
• **Indicator Recognition (+30 pts):** Points awarded for each correctly tagged red flag (spoofed domain, urgent threats, unmasked cards).
• **Credential Disclose Penalty (-70 to -100 pts):** Immediate loss of points upon submitting credentials or passwords.
• **Risk Classifications:** 80-100: Cyber Resilient (Low Risk); 50-79: Cautious (Moderate Risk); 0-49: Critical Vulnerability.

Post-Simulation Awareness Report: The trainee is immediately transitioned to AwarenessReportView.jsx, which provides an academic attack classification, psychological pretext breakdown, side-by-side indicator comparisons, and a one-click **'Redo Simulation'** option for positive behavioral reinforcement.

8. Database Models (MongoDB Atlas / Mongoose)

The persistence layer is structured into four primary collections:

- **Session:** Tracks active state, scenario data snapshot, attack channel, difficulty, and terminal status (active, completed, compromised, reported).
- **SimulationEvent:** Immutable event audit ledger storing timestamps, event types, target identifiers, and interaction payloads.
- **BehaviorScore:** Aggregated metrics including numerical vigilance score, response latency, and recognized indicators.
- **AwarenessReport:** Permanent educational report storing academic taxonomy, psychological triggers, and tailored remediation.

9. Automated Verification & Quality Assurance

The platform maintains 100% test pass coverage across backend API services and frontend React UI components:

Test Suite	Tests Passed	Coverage Areas
Backend Vitest	14 / 14 Passed	Detective challenge generation, multilingual call auto-detection, URL sanitization, scoring.
Frontend Vitest	164 / 164 Passed	All 8 simulators, landing page UI, telemetry dispatch, report rendering, detective workflow.